



THREAT ADVISORY

**ACTOR
REPORT**

KNOTWEED exploits zero-days to target US and Europe

Date of Publication

July 29, 2022

Admiralty code

A1

TA Number

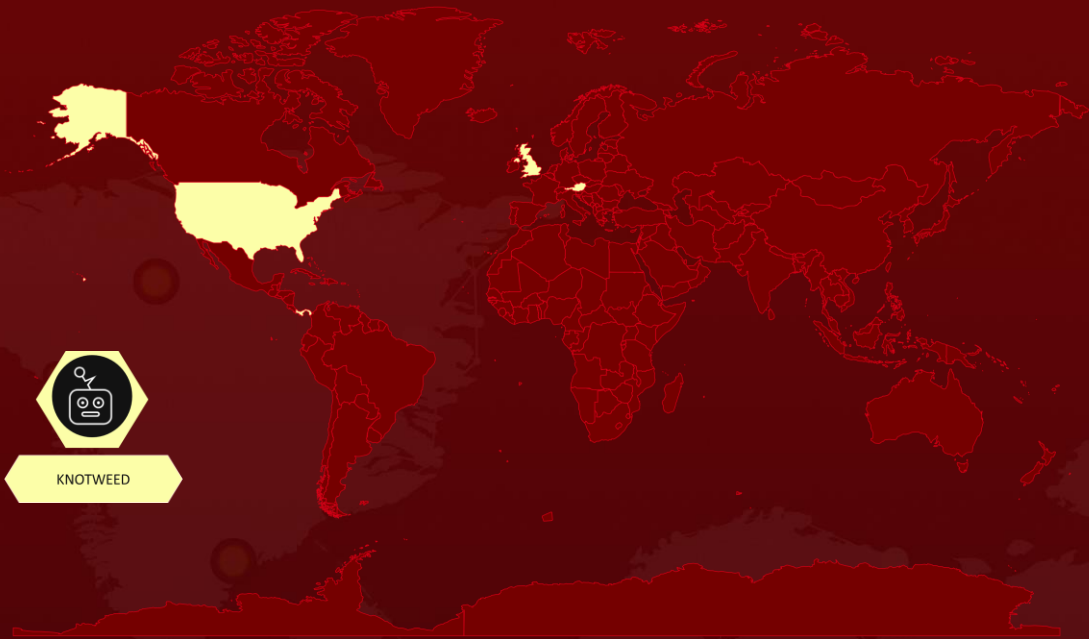
TA2022161

Summary

KNOTWEED, an Austria-based private-sector offensive actor (PSOA), are exploiting 0-day vulnerabilities of Windows and Adobe to perform targeted attacks against European and Central American customers by using their malware named Subzero.

⚙️ CVE Table

CVE	NAME	PATCH
CVE-2022-22047	Windows CSRSS Elevation of Privilege Vulnerability	✓
CVE-2021-31199	Microsoft Enhanced Cryptographic Provider Elevation of Privilege Vulnerability	✓
CVE-2021-31201	Microsoft Enhanced Cryptographic Provider Elevation of Privilege Vulnerability	✓
CVE-2021-28550	Acrobat Reader Use After Free Vulnerability	✓
CVE-2021-36948	Windows Update Medic Service Elevation of Privilege Vulnerability	✓



Powered by Bing
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom, Wikipedia

 Potential MITRE ATT&CK TTPs

TA0001 Initial Access	TA0004 Privilege Escalation	TA0003 Persistence	TA0005 Defense Evasion
TA0007 Discovery	TA0002 Execution	TA0009 Collection	T1566 Phishing
T1068 Exploitation for Privilege Escalation	T1546 Event Triggered Execution	T1140 Deobfuscate/Decode Files or Information	T1550 Use Alternate Authentication Material
T1518 Software Discovery	T1547 Boot or Logon Autostart Execution	T1027 Obfuscated Files or Information	T1560 Archive Collected Data
T1059 Command and Scripting Interpreter	T1553 Subvert Trust Controls		

Technical Details

#1

In 2022, KNOTWEED launched attacks by exploiting a zero-day vulnerability in Microsoft, CVE-2022-22047, to take control of the vulnerable machine, escape sandboxes, gain system-level code execution and escalate privileges.

#2

In 2021, KNOTWEED launched two different attacks, one by chaining Windows privilege escalation exploits (CVE-2021-31199 and CVE-2021-31201) with Adobe Reader exploit (CVE-2021-28550). And another one is by exploiting a Windows privilege escalation vulnerability in the Windows Update Medic Service (CVE-2021-36948).

#3

The downloader shellcode is the first shellcode to be launched from either malicious Excel documents or exploit chains in order to retrieve the Subzero, a second-stage malware, from the actor's command-and-control (C2) server. The malware known as Subzero is loaded into memory via the Subzero persistence loader.



Actor Detail

NAME	ORIGIN	MOTIVE	TARGET LOCATIONS	TARGET INDUSTRIES
KNOTWEED	Austria	Financial Gain	Austria, the United Kingdom, USA, and Panama	Law firms, Banks, and strategic consultancies

✂ Indicator of Compromise (IOC)

TYPE	VALUE
SHA-256	78c255a98003a101fa5ba3f49c50c6922b52ede601edac5db036ab72efc57629 0588f61dc7e4b24554cffe4ea56d043d8f6139d2569bc180d4a77cf75b68792f 441a3810b9e89bae12eea285a63f92e98181e9fb9efd6c57ef6d265435484964 cbae79f66f724e0fe1705d6b5db3cc8a4e89f6bdf4c37004aa1d45eeab26e84b fd6515a71530b8329e2c0104d0866c5c6f87546d4b44cc17bbb03e64663b11fc 5d169e083faa73f2920c8593fb95f599dad93d34a6aa2b0f794be978e44c8206 7f29b69eb1af1cc6c1998bad980640bfe779525fd5bb775bc36a0ce3789a8bfc 02a59fe2c94151a08d75a692b550e66a8738eb47f0001234c600b562bf8c227d 7f84bf6a016ca15e654fb5ebc36fd7407cb32c69a0335a32bfc36cb91e36184d afab2e77dc14831f1719e746042063a8ec107de0e9730249d5681d07f598e5ec 894138dfeee756e366c65a197b4dbef8816406bc32697fac6621601debe17d53 4611340fdade4e36f074f75294194b64dcf2ec0db00f3d958956b4b0d6586431 c96ae21b4cf2e28eec222cfe6ca903c4767a068630a73eca58424f9a975c6b7d fa30be45c5c5a8f679b42ae85410f6099f66fe2b38eb7aa460bcc022babb41ca e64bea4032cf2694e85ede1745811e7585d3580821a00ae1b9123bb3d2d442d6
Domains	acrobatrelay[.]com finconsult[.]cc realmetaldns[.]com

Patch Links

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-22047>

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-31201>

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-31199>

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-36948>

<https://helpx.adobe.com/security/products/acrobat/apsb21-29.html>

References

<https://www.microsoft.com/security/blog/2022/07/27/untangling-knotweed-european-private-sector-offensive-actor-using-0-day-exploits/>

What Next?

Book a free demo with **HivePro Uni5** to check your exposure to this advisory. HivePro Uni5 is a Threat Exposure Management Solution that proactively reduces an organization's attack surface before it gets exploited.



At Hive Pro we take a long hard look at your vulnerabilities so you can bolster your defenses and fine-tune your offensive cybersecurity tactics.

REPORT GENERATED ON

July 29, 2022 • 6:00 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com